

Privacy in Internet — Exam Study Guide

Master in IT-Security. Each answer is written to be exam-usable, with a “Where to read more” pointer at the end of each item. Primary sources (regulations, RFCs, W3C specs, original papers) are preferred over secondary blogs.

1. Areas where IT security and privacy have conflicting goals

Security and privacy mostly reinforce each other (confidentiality protects both), but they collide wherever **security wants more data / more identification** and **privacy wants less of both**:

- **Logging & accountability vs. data minimisation / unlinkability.** Forensics, audit trails and intrusion detection want extensive, long-retained logs; data-minimisation and storage-limitation principles want the opposite.
- **Strong authentication / identification vs. anonymity & pseudonymity.** Knowing exactly who acts is a security goal; not being identifiable is a privacy goal. Biometrics give strong authentication but collect highly sensitive personal data.
- **Monitoring / Deep Packet Inspection / content scanning vs. confidentiality of communication.** Malware scanning, spam filtering and DLP require reading content; privacy wants end-to-end confidentiality.
- **Availability / backups vs. the right to erasure.** Redundant backups and immutable ledgers fight against deletion (GDPR Art. 17), especially on blockchains.
- **Centralised identity / single sign-on vs. unlinkability.** Centralising identity simplifies security management but enables cross-service correlation.
- **Attribution / non-repudiation vs. plausible deniability.**

A useful framing: the classic security triad (Confidentiality, Integrity, Availability) vs. the **protection goals of privacy** (Unlinkability, Transparency, Intervenability — the “Standard Data Protection Model” / Rost & Pfitzmann).

Where to read more: M. Hansen, M. Jensen, M. Rost, “Protection Goals for Privacy Engineering” (IEEE S&P Workshops 2015); ENISA “Privacy and Data Protection by Design.”

2. The 8 OECD Privacy Principles

From the **OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal Data** (1980, revised 2013):

1. **Collection Limitation** — limits to collection; lawful, fair, with knowledge/consent.
2. **Data Quality** — data relevant, accurate, complete, up to date.

3. **Purpose Specification** — purposes specified at collection.
4. **Use Limitation** — no use/disclosure beyond specified purposes except with consent or by law.
5. **Security Safeguards** — reasonable safeguards against loss, unauthorised access, modification, disclosure.
6. **Openness** — transparency about practices and policies.
7. **Individual Participation** — right to access, confirm, challenge and erase one's data.
8. **Accountability** — the data controller is accountable for complying with the principles.

Where to read more: OECD Guidelines (2013), oecd.org. These principles are the conceptual ancestor of the GDPR principles (Art. 5).

3. Defined roles in the GDPR

- **Data Subject** — the identified/identifiable natural person (Art. 4(1)).
- **Controller** — determines the *purposes and means* of processing (Art. 4(7)); bears primary responsibility.
- **Processor** — processes personal data *on behalf of* the controller (Art. 4(8)); bound by Art. 28 contract.
- **Joint Controllers** — two+ controllers jointly determining purposes/means (Art. 26).
- **Recipient** — anyone to whom data is disclosed (Art. 4(9)).
- **Third Party** — anyone other than subject, controller, processor and those authorised to process (Art. 4(10)).
- **Data Protection Officer (DPO)** — appointed in defined cases; monitors compliance (Arts. 37–39).
- **Supervisory Authority (SA)** — national DPA enforcing the GDPR (Art. 51 ff.).
- **Representative** — EU-based representative for non-EU controllers/processors (Art. 27).
- **European Data Protection Board (EDPB)** — ensures consistent application (Art. 68 ff.).

Where to read more: Regulation (EU) 2016/679, Arts. 4, 24–39, 51, 68.

4. “Privacy by Design” strategies

Core idea (context): privacy can be improved not only by **legal means** or by **data-protection technologies (PETs)** bolted on afterwards, but by **building the privacy goal into the system already at the design stage**. PbD is proactive and embedded, not retrofitted — and it is a legal obligation under GDPR Art. 25 (**data protection by design and by default**).

The lecture presents **two concrete strategies** to achieve it:

Strategy 1 — Data minimization. “Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which it is processed” (GDPR Art. 5(1)(c)). Memorable form: “**you cannot lose what you do not have**” — not holding data is the strongest protection. This reverses the older **data-maximization** mindset (collect everything), which was encouraged by (a) cheap storage and (b) the big-data-mining promise. Operationalise it with four design questions: - **What data do we need?** Collect

only the answer required, not the raw datum — e.g. to check if someone is a child, ask that, don't collect a full birth date. (*OECD Collection Limitation.*) - **How long is it needed?** Erase data once it no longer serves the purpose. (*Art. 5(1)(e) storage limitation; Art. 17 erasure.*) - **How many copies?** Fewer copies = smaller breach surface = less risk. - **What purpose?** Use it solely for the purpose it was collected for. (*Art. 5(1)(b) purpose limitation.*)

Strategy 2 — Pseudonymisation. Processing personal data so it **can no longer be attributed to a specific data subject without additional information**, which is kept separately (**GDPR Art. 4(5)**). If pseudonymised data is breached, it does not (by itself) harm the individual, because the attacker gets tokens, not identities. **Key distinction:** pseudonymisation is *reversible* (the link still exists, stored separately) so the data **remains personal data under the GDPR**; **anonymisation** is *irreversible* and takes data out of GDPR scope. Techniques: - **Encryption** — unreadable without the key. - **Hashing** — one-way replacement of identifiers. (*Caveat: plain hashing of low-entropy values is brute-forceable / rainbow-table-attackable; use salted or keyed hashing.*) - **Masking** — replace part of the value (e.g. show only the last 4 digits). - **Aggregation** — combine records into group statistics so no individual is distinguishable. (*Strong aggregation shades into anonymisation; same idea behind k-anonymity / differential privacy.*) - **Indirect references / tokenisation** — store a pointer; keep the real data in a separate, better-protected store.

These are measures the **controller** takes, and the GDPR rewards them: named in **Art. 25** (PbD) and **Art. 32** (security of processing), and under **Art. 34** breach notification to individuals may be waived if data was rendered unintelligible (e.g. encrypted) — so the harm *and* the fine are lower.

Where to read more: R. Chow, “Privacy by Design” (2014, the lecture's optional reading); GDPR Arts. 4(5), 5(1)(b)(c) (e), 17, 25, 32, 34. (Broader academic taxonomy for reference: Hoepman's 8 strategies — Minimise/Hide/Separate/Aggregate/Inform/Control/Enforce/Demonstrate — where these two map onto Minimise, Hide and Aggregate.)

5. The four sections a DPIA must contain (GDPR Art. 35(7))

A Data Protection Impact Assessment must contain at least:

- (a) a **systematic description** of the envisaged processing operations and the **purposes**, including (where applicable) the controller's legitimate interest.
- (b) an assessment of the **necessity and proportionality** of the processing in relation to the purposes.
- (c) an assessment of the **risks to the rights and freedoms** of data subjects.
- (d) the **measures envisaged to address the risks** — safeguards, security measures and mechanisms to ensure protection of personal data and to demonstrate compliance.

Where to read more: GDPR Art. 35; WP29 / EDPB “Guidelines on DPIA” (WP248 rev.01).

6. U-Prove: interactions between actors

U-Prove (Brands' cryptography, developed by Microsoft) is a privacy-preserving credential (“token”) system. **Three actors:**

- **Issuer** — vouches for attributes and issues a **U-Prove token**.
- **Prover (User/holder)** — receives the token and later proves attributes from it.

- **Verifier (Relying Party)** — checks the token and the disclosed attributes.

Two protocols / interactions:

1. **Issuance (Issuer ↔ Prover)**. A blinded issuance protocol produces a token carrying attributes signed by the issuer. Because of the blinding, the **issuer cannot later recognise the token** when it is shown (issuer–verifier unlinkability).
2. **Presentation (Prover ↔ Verifier)**. The prover presents the token, proves it was issued by the trusted issuer, and discloses a chosen subset of attributes. Different tokens are **mutually unlinkable**.

Where to read more: C. Paquin, “U-Prove Cryptographic Specification V1.1” (Microsoft); S. Brands, *Rethinking Public Key Infrastructures and Digital Certificates* (MIT Press, 2000).

7. U-Prove selective disclosure mechanism

A U-Prove token binds a set of attributes ($A_1, \dots, A_n$) under the issuer’s signature. At presentation the prover decides, **per attribute**, whether to **disclose** it or keep it **hidden**:

- Disclosed attributes are revealed in clear.
- Hidden attributes remain committed inside the token; the cryptographic structure (the token’s public key is a commitment formed from all attributes and blinding values) lets the verifier confirm the issuer’s signature is **still valid over the full set** without learning the hidden values.
- The prover can additionally produce proofs *about* undisclosed attributes (e.g. proving an inequality) without revealing them.

The result: the verifier learns exactly the chosen attributes plus the fact that all attributes were genuinely issued, and nothing more (data minimisation).

Where to read more: U-Prove Cryptographic Specification §”Presentation Proof.”

8. SSI Architecture

Self-Sovereign Identity is built around the “**trust triangle**” plus a registry:

- **Issuer** — issues **Verifiable Credentials (VCs)** to a holder.
- **Holder** — stores VCs in a **wallet** and creates **Verifiable Presentations (VPs)** for verifiers.
- **Verifier (Relying Party)** — receives a VP and checks it.
- **Verifiable Data Registry (VDR)** — usually a distributed ledger/blockchain; stores **DIDs, DID documents (public keys), schemas, and revocation registries** — *not* the personal data itself.

Flow: Issuer → (VC) → Holder → (VP) → Verifier; both issuer and verifier resolve DIDs and public keys via the VDR to check signatures and revocation. The holder is in the centre and controls disclosure.

Conceptually layered (the **Trust over IP** stack): ledger/DID layer → DIDComm/peer layer → credential exchange layer → application/governance layer.

Where to read more: W3C VC Data Model; Trust over IP Foundation; A. Preukschat & D. Reed, *Self-Sovereign Identity* (Manning, 2021).

9. What is the DID designed and used for?

A **Decentralized Identifier (DID)** is a globally unique identifier that requires **no central registration authority**. Format: `did:method:method-specific-id` (e.g. `did:web:example.com`).

Designed for / used for: - **Decentralisation** — no central registry/CA needed. - **Self-control** — the identifier is created and controlled by its subject. - **Persistence** — long-lived, independent of any organisation. - **Cryptographic verifiability** — resolves to a **DID document** containing public keys, enabling proof of control (authentication) and signing. - Identifying any subject: people, organisations, devices, data, abstract entities.

Where to read more: W3C “Decentralized Identifiers (DIDs) v1.0” Recommendation (2022).

10. Replacing the Certification Authority in a decentralized PKI

In classic PKI a hierarchy of trusted **CAs** binds keys to identities. In a **Decentralized PKI (DPKI)** the CA’s role of “authoritative key directory” is replaced by:

- **A distributed ledger / blockchain** acting as a tamper-evident, append-only **public key registry** (each DID’s keys are recorded and updated by the key owner). Consensus replaces a single trusted authority.
- **Web of Trust** (PGP-style) — peers cross-sign each other’s keys; trust accrues from many attestations instead of one CA.
- **Self-certifying identifiers** — the identifier is derived from (or bound to) the public key itself, so no external authority is needed to bind name→key.
- **Key transparency / append-only logs** (analogous to Certificate Transparency) to make any key change publicly auditable.

These remove the single point of trust/failure and give key control to the identity owner.

Where to read more: C. Allen et al., “Decentralized Public Key Infrastructure” (Rebooting the Web of Trust whitepaper, 2015).

11. Structure of a Verifiable Credential

A W3C VC has three logical parts:

1. **Credential metadata** — `@context`, `id`, `type`, `issuer`, validity dates (`validFrom` / `expirationDate`), optionally `credentialStatus` (revocation pointer), `credentialSchema`.
2. **Claims** — the `credentialSubject`: the actual statements/attributes about the subject (e.g. name, date of birth, degree).

3. **Proof** — the cryptographic **proof** block (digital signature / proof type, verification method, created date) that makes it tamper-evident and verifiable.

A **Verifiable Presentation (VP)** wraps one or more VCs and adds the **holder's** proof, so the verifier can check both issuer authenticity and holder binding.

Where to read more: W3C “Verifiable Credentials Data Model v2.0.”

12. Privacy enhancements in SSI interactions (holder / issuer / verifier)

- **Selective disclosure** — holder reveals only the attributes a verifier needs (e.g. just “country = AT”).
- **Zero-knowledge / predicate proofs** — prove a predicate (e.g. $age \geq 18$) without revealing the underlying value (date of birth).
- **Pairwise / peer DIDs** — a fresh DID per relationship, so different verifiers cannot correlate the same holder.
- **No “phone home”** — the issuer is not contacted at presentation time, so it never learns *where/when* a credential is used.
- **Local storage** — credentials live in the holder's wallet, removing the central honeypot.
- **Unlinkable presentations** — signature schemes such as **BBS+** / CL signatures let the same credential be shown many times without the presentations being linkable.
- **Data minimisation by default** — holder consents to each disclosure.

Where to read more: Hyperledger Aries/Indy; BBS+ Signatures (D. Boneh, J. Camenisch); W3C VC Data Model §privacy considerations.

13. What a DID document contains

Resolving a DID yields a **DID document** (typically JSON-LD). It contains:

- **id** — the DID itself.
- **@context**.
- **controller** — entity authorised to make changes.
- **verificationMethod** — the set of **public keys** (and key material/type).
- **Verification relationships** that say *how* each key may be used: **authentication**, **assertionMethod**, **keyAgreement**, **capabilityInvocation**, **capabilityDelegation**.
- **service** / **serviceEndpoint** — endpoints for interacting with the subject (e.g. DIDComm messaging, credential services).
- optionally **alsoKnownAs**.

Crucially it contains **no personal data** — only keys, relationships and endpoints.

Where to read more: W3C “DIDs v1.0,” §“Core Properties.”

14. Identified challenges for the spread of SSI

- **Interoperability / standardisation** — many DID methods, wallet apps and credential formats that don’t all interwork.
- **Key management & recovery** — losing private keys means losing identity; usable recovery is hard.
- **Usability** — wallets and key concepts are too technical for ordinary users.
- **Network effects (chicken-and-egg)** — value requires many issuers *and* many verifiers simultaneously.
- **Governance / trust frameworks** — who is an authoritative issuer, and how is that trust established and policed?
- **Legal recognition & GDPR tension** — immutable ledgers vs. the right to erasure; legal status of credentials.
- **Revocation** that is timely yet privacy-preserving.
- **Scalability & cost** of the underlying ledger.
- **Business incentives** — unclear who pays.

Where to read more: Sovrin Foundation reports; SSI sections of eIDAS 2.0 analyses (e.g. arXiv 2601.19837).

15. Advantages of eIDAS compared to SSI

- **Legal certainty & legal effect** — e.g. qualified electronic signatures have legal equivalence to handwritten signatures; cross-border legal validity is guaranteed.
- **High level of assurance** — identity is rooted in **state-issued** identity proofing (“State-Supported Identity”) rather than ad-hoc issuer trust.
- **Mandatory mutual recognition** across all Member States.
- **Established, regulated trust framework** — Qualified Trust Service Providers, Trusted Lists, supervision and **defined liability**, instead of SSI’s still-maturing governance.
- **Standardisation is mandated by regulation**, reducing fragmentation.
- **Clear accountability and supervision** — a regulator stands behind it.

Where to read more: Regulation (EU) 910/2014 and (EU) 2024/1183; “The European Digital Identity Wallet as Defined in the eIDAS 2 Regulation” (Springer, 2024).

16. “In eIDAS 2.0 a verified and secure identification is essential” — implications for people in the EU

This statement means the framework is built on **high-assurance, government-rooted identity** rather than anonymity-by-default. For EU residents it implies:

- Each Member State must **offer every citizen/resident an EU Digital Identity (EUDI) Wallet** by end of 2026 (provision is mandatory; *using* it is voluntary).
- When they identify themselves online or offline, the identification can be **strongly and reliably verified** and bound to their real legal identity and secure device — reducing fraud and enabling trusted cross-border services (banking, public services, signatures).
- Benefits: convenience, portability across the EU, fewer fragmented logins, and (via selective disclosure) **disclosing only what is necessary**.
- Tensions/responsibilities: because identity is verified and state-backed, there are **profiling/surveillance concerns**; hence the regulation mandates **unobservability** (infrastructure providers must not track usage), **pseudonyms**, and **privacy by design/default**. Users also bear responsibility for **secure device and key management**.

Where to read more: Regulation (EU) 2024/1183, esp. Recitals 15 and 59 and Art. 5a.

17. Advanced SSI features that will also be available in eIDAS 2.0

- **Holder-controlled wallet** (EUDI Wallet) storing **Verifiable Credentials** as Electronic Attestations of Attributes (EAA/QEAA).
- **Selective disclosure** of attributes — a *basic design feature* of the wallet (e.g. prove “over 18” without the exact birthdate).
- **Zero-knowledge proofs** — the regulation foresees ZK attestation where identification is not required (though the current Architecture & Reference Framework leans on commitment-based SD-JWT / ISO mdoc rather than full ZKP).
- **Combining attributes from multiple distinct attestations** in one presentation.
- **Pseudonyms** and **unobservability** (anti-profiling).
- Standard exchange protocols (**OpenID4VCI / OpenID4VP**) and formats (**SD-JWT VC, ISO/IEC 18013-5 mdoc**).

Where to read more: EUDI Wallet Architecture and Reference Framework (ARF); walt.id “eIDAS 2 Explained”; arXiv 2401.08196 (selective disclosure mechanisms).

18. The database privacy problem and what a good solution should achieve

The problem (statistical disclosure control): how to release useful statistics or answer queries over a dataset of individuals **without revealing information about any single individual** — even though

apparently harmless aggregate releases can leak individuals via **differencing attacks**, **linkage** with external data, or repeated querying.

A good solution should achieve: - **Utility** — released answers/statistics remain accurate and useful. - **Privacy** — an adversary cannot infer the presence/absence or attributes of any individual. - **Robustness to auxiliary knowledge** — the guarantee must not depend on what side information the attacker has (this is why ad-hoc anonymisation like k -anonymity fails against linkage). - **Composition** — privacy degrades gracefully and provably under many queries. - **A quantifiable, provable guarantee.**

Differential privacy is the canonical solution meeting these criteria.

Where to read more: C. Dwork & A. Roth, “The Algorithmic Foundations of Differential Privacy” (2014), Ch. 1–2.

19. Local vs. Global Differential Privacy

- **Global (central) DP:** a **trusted curator** holds all raw data and adds noise to the *outputs/answers*. Needs less total noise → **better utility**, but you must trust the curator with the raw data.
- **Local DP (LDP):** each user **randomises/perturbs their own data on their device** before sending it to an **untrusted** aggregator. No trusted curator needed → **stronger trust model**, but each record is noised independently → **much more noise / worse utility**. Used in production by Apple and by Google’s **RAPPOR**.

Where to read more: Dwork & Roth (2014); Ú. Erlingsson et al., “RAPPOR” (CCS 2014).

20. What Differential Privacy guarantees

Informally: **the inclusion or exclusion of any single individual’s record barely changes the output distribution of the analysis** — so an adversary learns essentially nothing specific about any individual, *regardless of their background knowledge*.

Formally, a randomised mechanism **M** is **ϵ -differentially private** if for every pair of **neighbouring datasets** D, D' (differing in one record) and every set of outputs S :

$$\Pr[M(D) \in S] \leq e^{\epsilon} \cdot \Pr[M(D') \in S]$$

For **(ϵ, δ) -DP** an additive slack δ is allowed: $\Pr[M(D) \in S] \leq e^{\epsilon} \cdot \Pr[M(D') \in S] + \delta$.

It gives **plausible deniability** to each individual. It does **not** promise you learn nothing — *population-level* facts can still be learned; it only bounds what is learnable about *any one* person.

Where to read more: Dwork & Roth (2014), Definition 2.4.

21. Calculating the sensitivity of a query

The **(global) ℓ_1 -sensitivity** of a function f is the maximum change its output can undergo when **one** record is added/removed:

$$\Delta f = \max \text{ over neighbouring } D, D' \text{ of } \| f(D) - f(D') \|_1$$

It captures the maximum influence a single individual can have on the result, and it determines how much noise is needed.

Examples: - **Counting query** (“how many rows satisfy P ?”): $\Delta f = 1$. - **Sum** of an attribute bounded to $[0, m]$: $\Delta f = m$. - **Mean** over n records of values in $[0, m]$: $\Delta f \approx m/n$.

(For the Gaussian mechanism one uses ℓ_2 -sensitivity instead.)

Where to read more: Dwork & Roth (2014), Definition 3.1.

22. Epsilon and its relation to the amount of Laplacian noise

ϵ (**epsilon**) is the **privacy-loss / privacy-budget** parameter. Smaller $\epsilon \Rightarrow$ **stronger privacy** (outputs on neighbouring datasets are nearly indistinguishable) but **more noise / less utility**; larger $\epsilon \Rightarrow$ weaker privacy, less noise.

The **Laplace mechanism** answers a query f as:

$$M(D) = f(D) + \text{Lap}(b), \text{ with scale } b = \Delta f / \epsilon$$

So the noise scale is **proportional to sensitivity Δf** and **inversely proportional to ϵ** . The Laplace distribution has variance $2 \cdot b^2 = 2 \cdot (\Delta f / \epsilon)^2$. Halving ϵ doubles the noise scale; a query with larger sensitivity needs proportionally more noise.

Where to read more: Dwork & Roth (2014), Theorem 3.6 (Laplace mechanism).

23. Tracking methods that use storage at the user (browser, device)

These persist an identifier on the client and read it back later (“stateful” tracking):

- **HTTP cookies** — first-party and **third-party cookies** (the classic cross-site tracker).
- **Flash cookies / Local Shared Objects (LSOs)** — historically used to back up and respawn deleted cookies.
- **HTML5 storage** — `localStorage`, `sessionStorage`, **IndexedDB**, (old Web SQL).
- **HTTP cache abuses** — **ETag**/Last-Modified tracking; cached resources (incl. **favicon cache**) carrying IDs.
- **HSTS “supercookies.”**

- **Evercookies** / “**zombie cookies**” — store the same ID in many of the above locations so that deleting one causes it to **respawn** from the others.

Where to read more: A. Soltani et al., “Flash Cookies and Privacy” (2009); S. Kamkar, “evercookie.”

24. How cookie-less tracking works

When cookies are blocked/cleared, trackers fall back on **stateless or alternative-state** signals:

- **Browser/device fingerprinting** (see Q25) — identify the device by its characteristics, storing nothing.
- **IP address** and network-level signals.
- **Cache/ETag-based** persistence.
- **First-party + server-side data sharing** — the site stores the ID server-side and shares it (e.g. via server-to-server APIs), defeating browser cookie controls.
- **Login / authenticated identifiers** and **hashed-email identifiers** (e.g. industry “Unified ID” schemes) that follow a logged-in user across sites.
- **Probabilistic matching** — combine signals (IP + UA + behaviour + timing) to link sessions statistically.
- **Privacy-Sandbox-style** interest signals (Google **Topics API**) — on-device interest categories instead of cross-site cookies.

Where to read more: Google Privacy Sandbox docs; literature on stateless tracking (below).

25. Browser fingerprinting and defences

How it works: JavaScript and HTTP headers expose many device/browser attributes whose **combined entropy** is often unique: user-agent, OS, language/timezone, screen resolution, installed **fonts** and plugins, hardware concurrency, **Canvas fingerprinting** (rendering text/graphics that vary by GPU/driver), **WebGL** and **AudioContext** fingerprints, battery, sensors. No identifier is stored on the client, so it is **stateless** and survives cookie deletion and private browsing.

Defences: - **Tor Browser** — deliberately makes all users look identical (uniform fingerprint). - **Firefox resistFingerprinting** / **Brave** — randomise or normalise canvas/WebGL/audio readings. - **Reduce attack surface** — disable JavaScript or specific APIs; standard, common configurations (being “normal” lowers uniqueness). - **Anti-fingerprinting extensions**; blocking known fingerprinting scripts. - Note: blocking *some* signals can paradoxically make you *more* unique, so uniformity (Tor approach) is generally stronger than partial spoofing.

Where to read more: P. Eckersley, “How Unique Is Your Web Browser?” (PETS 2010, EFF Panopticlick); the **AmIUnique** project.

26. How search engines threaten privacy

- **Query logs** tied to an IP or account reveal interests, health concerns, finances, location, and **intentions** — a uniquely intimate record.
- **Profiling for ad targeting**, cross-service linkage when the search account is also used for mail, maps, video, etc.
- **Personalisation / filter bubbles** shape what information you see.
- **De-anonymisation of logs** — even “anonymised” query logs can re-identify individuals (the 2006 **AOL search-log release** identified real users).
- **Location leakage** through localised results and autocomplete.
- **Government/legal access** — logs are subject to subpoenas and surveillance requests.

Mitigations: privacy-focused engines (DuckDuckGo, Startpage), querying via Tor, not staying logged in.

Where to read more: The 2006 AOL search-data incident; analyses of search-engine privacy policies.

27. How predictive analytics works + 3 application scenarios

How it works: historical (labelled) data is used to **train a statistical/ML model** that maps input features to an outcome; the model then estimates the **probability of a future outcome** for new inputs. Pipeline: data collection → cleaning & **feature engineering** → model training (regression, classification, tree ensembles, neural nets) → validation → **prediction** → decision/action → monitoring & retraining.

Three application scenarios: 1. **Finance** — credit scoring / loan default prediction; fraud detection. 2. **Healthcare** — predicting disease onset, hospital readmission, or patient deterioration. 3. **Marketing / operations** — customer **churn** prediction and recommendations; or **predictive maintenance** in manufacturing (forecasting equipment failure).

Where to read more: Any data-mining text (e.g. Hastie, Tibshirani, Friedman, *Elements of Statistical Learning*).

28. Using tracking data to predict health, fitness, and car-insurance fees

- **Health & fitness:** wearables and phones log steps, heart rate, sleep, and movement; combined with search history and purchases, models infer fitness level, conditions, even pregnancy (the well-known **Target** case predicted pregnancy from shopping patterns). Health insurers run “active rewards” programmes that price using fitness data.
- **Car insurance (Usage-Based Insurance / telematics):** a dongle or app records **mileage, speed, harsh braking/acceleration, cornering, time-of-day, and location**; a risk model turns this driving behaviour into a **personalised premium** (“pay-how-you-drive”).
- **Risks:** sensitive inferences from non-sensitive raw data; **dynamic/discriminatory pricing**; denial of coverage; chilling effects; secondary use beyond the original purpose.

Where to read more: C. Duhigg, “How Companies Learn Your Secrets” (NYT, 2012, Target case); literature on telematics/UBI.

29. Social bots: how they work, impacts, and targets

How they work: automated or semi-automated social-media accounts that imitate humans — posting, liking, sharing, following — often operated in **coordinated swarms (botnets)**, sometimes with AI-generated text and profile images to appear authentic. They **amplify** chosen content, fabricate engagement, and create the illusion of grassroots support (**astroturfing**).

Impacts on users: spread of **mis/disinformation**, manipulation of opinion and emotion, manufactured “consensus,” spam and phishing, harassment.

Other targets: - **Companies:** fake reviews and reputation attacks, coordinated brand damage, **stock/market manipulation** (pump-and-dump). - **Governments / democracy:** election interference, propaganda, amplifying polarisation, eroding trust in institutions and in the information ecosystem itself.

Where to read more: E. Ferrara et al., “The Rise of Social Bots” (Comm. ACM, 2016); Bessi & Ferrara on social bots in the 2016 US election.

30. Main differences between a Tor network and a Mix

Both anonymise by relaying through intermediaries, but they target different traffic and threat models:

Tor (onion routing) - Low-latency, built for interactive traffic (web browsing). - A **circuit of 3 relays** (guard → middle → exit) with **layered (“onion”) encryption**. - Forwards packets **in real time; no batching, delaying, or cover traffic**. - Therefore **weak against a global passive adversary / end-to-end timing-correlation** attacks.

Mix network (Chaumian mix) - High-latency, built for messaging (email). - Each mix **collects a batch of messages, reorders them, delays them, and adds dummy/cover traffic**, breaking the timing link between input and output; uses re-encryption so messages look bitwise different in and out. - **Strong against traffic analysis**, even a global passive adversary — but the latency makes it unsuitable for interactive browsing.

Key difference: mixes **deliberately delay and reorder (and pad)** to defeat traffic-correlation; Tor optimises for **low latency** and accepts weaker protection against a global adversary.

Where to read more: D. Chaum, “Untraceable Electronic Mail...” (CACM 1981); R. Dingledine et al., “Tor: The Second-Generation Onion Router” (USENIX Security 2004).

31. Threats from collecting user location

- **Re-identification:** location traces are highly unique — **four spatio-temporal points uniquely identify ~95%** of people (de Montjoye et al.). Home + work usually pin down an identity.

- **Sensitive inferences:** religion (place of worship), health (clinics/hospitals), sexual orientation, political activity (attending protests), relationships (co-location).
- **Physical-safety harms: stalking**, burglary (knowing when you're away).
- **Behavioural profiling** for advertising and price discrimination.
- **State surveillance** and aggregation across data brokers.
- **De-anonymisation** by combining “anonymous” location data with external datasets.

Where to read more: Y.-A. de Montjoye et al., “Unique in the Crowd: The Privacy Bounds of Human Mobility” (Scientific Reports, 2013).

32. Forbidden AI applications in the AI Act (Article 5)

Regulation (EU) 2024/1689, **Art. 5** bans eight categories (in force since 2 Feb 2025):

1. **Subliminal/manipulative/deceptive techniques** that materially distort behaviour and cause (or are likely to cause) significant harm.
2. **Exploiting vulnerabilities** due to age, disability, or a specific social/economic situation to distort behaviour and cause harm.
3. **Social scoring** by public or private actors leading to unjustified or **disproportionate detrimental treatment**.
4. **Predicting criminal offending based solely on profiling** or personality traits (predictive policing of individuals).
5. **Untargeted scraping of facial images** from the internet or CCTV to build/expand **facial-recognition databases**.
6. **Emotion recognition in the workplace and in education** (with narrow medical/safety exceptions).
7. **Biometric categorisation** inferring **sensitive attributes** (race, political opinions, religion, sexual orientation, etc.).
8. **Real-time remote biometric identification in publicly accessible spaces for law enforcement** — with narrow, authorised exceptions (e.g. searching for specific victims/missing persons, preventing an imminent terrorist threat, locating suspects of serious crimes).

Where to read more: Regulation (EU) 2024/1689, Art. 5; artificialintelligenceact.eu/article/5.

33. Main high-risk areas in the AI Act (Annex III)

High-risk under **Art. 6(2)** = the eight use-case areas of **Annex III** (plus Art. 6(1): AI that is a safety component of products regulated under Annex I harmonisation law, e.g. medical devices, machinery):

1. **Biometrics** — remote biometric identification, biometric categorisation, emotion recognition (where permitted).
2. **Critical infrastructure** — safety components in road traffic and the supply of water, gas, heating, electricity, and critical digital infrastructure.

3. **Education and vocational training** — admission, evaluation of learning outcomes, exam proctoring.
4. **Employment, workers management and access to self-employment** — recruitment, selection, promotion/termination, task allocation, performance monitoring.
5. **Access to essential private and public services and benefits** — e.g. **credit scoring/creditworthiness**, eligibility for public benefits, emergency-service dispatch, **health/life-insurance risk** assessment.
6. **Law enforcement** — individual risk assessment, evidence reliability evaluation, profiling.
7. **Migration, asylum and border-control management** — risk assessment, examination of visa/asylum applications.
8. **Administration of justice and democratic processes** — assisting judicial decision-making; AI used to influence elections/referenda.

(An Annex III system can be exempted under Art. 6(3) if it poses no significant risk to health/safety/fundamental rights.)

Where to read more: Regulation (EU) 2024/1689, Art. 6 and **Annex III**; artificialintelligenceact.eu/annex/3.

34. Why privacy is important in machine learning

- **Models are trained on personal data**, and the model itself can **leak** that data:
- **Membership inference** — an attacker can tell whether a specific person's record was in the training set.
- **Model inversion / attribute inference** — reconstruct sensitive attributes or representative inputs.
- **Memorisation & training-data extraction** — large models (especially LLMs) can regurgitate verbatim PII/secrets from training data.
- **Gradient leakage** — in distributed training, shared gradients can reveal inputs.
- **Legal compliance** — GDPR principles (purpose limitation, minimisation, lawful basis, the right to erasure) apply to training data and sometimes to models.
- **Trust, fairness and ethics** — privacy harms compound with bias/discrimination.

Defences: differentially private training (**DP-SGD**), **federated learning**, secure aggregation, data minimisation/anonymisation, output filtering.

Where to read more: R. Shokri et al., "Membership Inference Attacks Against ML Models" (IEEE S&P 2017); N. Carlini et al., "Extracting Training Data from Large Language Models" (USENIX Security 2021).

35. Federated learning architecture and how it better protects personal data

Architecture: a **central server** coordinates training across many **clients** (phones, browsers, hospitals, banks): 1. Server sends the current **global model** to a sample of clients. 2. Each client **trains locally on**

its own data and computes a model **update** (gradients/weights). 3. Clients send **only the updates** — never the raw data — back to the server. 4. The server **aggregates** updates (e.g. **Federated Averaging, FedAvg**) into an improved global model. 5. Repeat for many rounds.

Why it protects personal data better: - **Raw data never leaves the device** → data minimisation and no central data honeypot, reducing breach and misuse risk. - Naturally fits **GDPR purpose-limitation/minimisation** and data-locality/sovereignty requirements.

Caveat: model updates can still leak information (**gradient-leakage / inference attacks**), so federated learning is usually combined with **secure aggregation** and **differential privacy** to harden the guarantee.

Where to read more: B. McMahan et al., “Communication-Efficient Learning of Deep Networks from Decentralized Data” (AISTATS 2017) — the FedAvg paper.

Tip for the exam: the recurring themes that tie these topics together are data minimisation, unlinkability, provable vs. ad-hoc privacy guarantees, and the trust model (whom you must trust, and what they could do with the data). Many questions can be answered by reasoning from those four ideas.